Semana 09 — Regla YARA probada y deteccion reutilizable

Grupo 4 · rol Púrpura · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	09 de 10
Fase	4 — Forense y respuesta a incidentes
Grupo	4
Rol	Púrpura
Entrega	GitHub, carpeta semana_09/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Instrumenta la detección del mismo evento: activa el registro, define la alerta y mide lo que se habría visto, incluidos los falsos positivos y negativos.

- Instrumentar el evento, activando el registro que lo vería y definiendo la alerta con su umbral.
- Comparar lo que se registró con lo que se ejecutó, ítem por ítem del paso a paso.
- Reportar falsos positivos y negativos y proponer el ajuste concreto de la regla.

2 Qué aporta este rol al entregable

La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.

3 Ejemplo paso a paso

El rol Púrpura escribe la regla que detecta la muestra y la prueba contra un archivo limpio. Una regla que detecta todo no sirve; una que no se prueba tampoco.

3.1 Elegir cadenas discriminantes

Se eligen cadenas que no aparezcan en archivos normales. Las rutas genericas o palabras comunes producen falsos positivos y se descartan.

```
mkdir -p semana_09/evidencia
strings -n 8 muestra.bin | grep -E '/tmp/|http|chmod' \
  | sort -u | tee semana_09/evidencia/cadenas_candidatas.txt || true
```

3.2 Escribir la regla con condicion estricta

La condicion exige varias cadenas a la vez. Se documenta por que cada una esta y que se elimino por ser demasiado comun.

```
cat > semana_09/regla.yar <<'YAR'
rule muestra_curso {
  meta:
    autor = "Grupo 4"
    descripcion = "Ruta temporal y descarga en la misma muestra"
  strings:
    $a = "/tmp/" ascii
    $b = "http" ascii
    $c = "chmod" ascii
  condition:
    all of them
}
YAR
yara semana_09/regla.yar muestra.bin | tee semana_09/evidencia/
   yara_muestra.txt
```

3.3 Probar contra archivos limpios

Se ejecuta contra archivos del sistema que no deberian coincidir. Si coinciden, la regla se ajusta y se vuelve a probar.

```
yara semana_09/regla.yar /bin/ls > semana_09/evidencia/yara_limpio.txt
   2>&1 || true
wc -l < semana_09/evidencia/yara_limpio.txt
```

3.4 Documentar la cobertura y el limite

La regla detecta esta muestra, no la familia. El informe dice que cambios la evaden y que se necesitaria para generalizarla.

3.5 Cadena, motivo y resultado de la prueba

Cadena, motivo y resultado de la prueba

Cadena	Motivo	Discriminante	Prueba	Resultado
/tmp/	Ruta temporal usada en la muestra	Media	Contra /bin/ls	No coincide
http	Descarga remota	Baja	Contra /bin/ls	No coincide
chmod	Cambio de permisos	Media	Contra /bin/ls	No coincide
Combinacion	Exige las tres a la vez	Alta	Contra la muestra	Detecta

La columna de falsos positivos se llena con la prueba real contra archivos limpios.

4 Qué guardar en el repositorio

Se entrega la regla con metadatos, el resultado contra la muestra, la prueba contra archivos limpios y la declaracion de cobertura.

```
semana_09/
|-- informe.md
|-- regla.yar
|-- muestra.bin
|-- evidencia/
|   |-- cadenas_candidatas.txt
|   |-- yara_muestra.txt
|   `-- yara_limpio.txt
`-- README.md
```

- La regla exige una combinacion, no una cadena suelta.
- Se probo contra la muestra y contra al menos un archivo limpio.
- La cobertura se declara como muestra concreta, no como familia.
- Las cadenas descartadas estan justificadas.

5 Cómo se corrige

Criterio	Peso
Playbook operativo con fases y responsables	3,0
Triage estático completo y sin ejecutar la muestra	2,5
Regla YARA que detecta la muestra	2,0
Post mortem con mejoras priorizadas	1,5
Cumplimiento de las reglas de manejo de muestras	1,0
Total	**10,0**

- Una regla sin prueba contra limpios es una hipotesis, no una deteccion.
- La regla no se ejecuta sobre archivos del sistema fuera de la prueba declarada.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.